

Sprint 6 – Group Meeting Notes

Meeting Schedule with mentor (Steve)

- Sprint-6_Meeting-Notes: March 24 – April 8, 2026
- **Meeting Type:** Group meetings with mentor
- **Project:** Open Energy Dashboard (OED)

Role Assignment

- Zack Squires

General Summary

During Sprint 6, the team met with the mentor to review the status of all remaining security issues, focusing heavily on **final cleanup, merge readiness, and project stabilization** as the semester approaches completion.

The meeting emphasized that the team is now in a **wind-down phase**, where the priority is no longer starting new work, but instead:

- Resolving open pull requests
- Fixing merge conflicts
- Completing testing and validation
- Ensuring all work is properly documented and reviewable

The mentor made it clear that “**done for class**” is not the same as “**done for the project**”, and that all work must be in a **functional, clean, and reviewable state** before being considered complete.

Key Theme of Sprint 6

The central focus of this sprint is:

“Clean, test, document, and finalize everything.”

Priority order defined by the mentor:

1. Fully merged PR into OED
2. Clean PR ready for merge
3. PR available in team repo (Ball State)

4. Clear design/documentation
5. Verbal explanation (least preferred)

Issue-by-Issue Discussion Summary

Issue 1 – Critical (Unresolved / Blocked)

- Status: **Not complete (despite being marked done for class)**
- Associated PR: #1568 (and related DOMPurify work)
- Problem:
 - Merge conflicts unresolved for ~2 months
 - PR is not clean and cannot be merged
 - Mentor has **never been able to properly review it**
- Mentor Concern:
 - This is a **high-priority security issue**
 - Must be **fixed, cleaned, and reviewed before project completion**

Action Items:

- Resolve merge conflicts immediately
- Clean PR completely
- Resubmit for mentor review

Issue 2 – Secure Default Configuration (PR #1554)

- Status: **Substantially complete but not merged**
- Issues:
 - Requires additional testing
 - Some unresolved comments
 - Questions around **Docker secrets vs .env usage**
- Mentor Guidance:
 - Temporary solution: keep .env approach

- Long-term: move to proper **secrets management system**

Action Items:

- Resolve remaining PR comments
- Complete testing
- Prepare for merge

Issue 3 – DOMPurify / XSS Fix (PR #1591 replacing #1544)

- Status: **Ready for re-review**
- Notes:
 - Previous PR (#1544) replaced due to issues
 - New PR (#1591) submitted and cleaned
- Mentor:
 - Added to review queue

Action Items:

- Await mentor review
- Address any additional feedback

Issue 4 – OAI / Non-Root User (Docker Security)

- Status: **In progress**
- Key Decision:
 - Use a **non-privileged user** instead of default/root
- Mentor Explanation:
 - Avoid relying on Docker image users (e.g., Node)
 - Create a **controlled, low-privilege user for OED**
- Additional Work:
 - Investigate container hardening (read-only, privileges)

Action Items:

- Implement non-root user properly

- Document approach and reasoning
- Test behavior across containers

Issue 5 – Hard-Coded Credentials / Secret Management

- Status: **Partially addressed**
- Key Direction:
 - Decouple from Issue 2 if needed
 - Focus on **research + documentation**
- Mentor Expectation:
 - Provide:
 - Options for secret management
 - Possible implementation approach
 - Testing if feasible

Action Items:

- Document vault/secret manager options
- Provide design-level explanation
- Optional: prototype/test

Issue 6 – Content Security Policy (PR #1567)

- Status: **Incomplete**
- Problems:
 - Merge conflicts
 - Unresolved formatting issues
 - Browser console shows **security warnings**
- Mentor Concern:
 - Console errors indicate **possible misconfiguration**

Action Items:

- Resolve merge conflicts

- Fix formatting issues
- Investigate and eliminate console warnings

Issue 7 – Dependency / Package Updates

- Status: **Functionally complete (team side)**
- Notes:
 - Security updates identified
 - Upgrading packages is complex (breaking changes possible)
- Mentor Decision:
 - Mark as **future OED work**

Issue 9 – File Upload DoS

- Status: **PR exists but unclear review status**
- Issue:
 - Mentor could not find review record
- Action Required:
 - Confirm PR status with Krista
 - Ensure mentor review happens

Issue 10 – Secure Password Authentication

- Status: **In progress**
- Work:
 - Password validation improvements
 - Considering library vs custom implementation
- Additional Concern:
 - Password truncation (~72 chars)

Mentor Guidance:

- Add UI validation for max length
- If not implemented → create issue

Issue 11 – (Ball State Side Work)

- Status: **Needs verification**
- Concern:
 - Changes not clearly visible or confirmed

Action Items:

- Verify functionality
- Prepare PR or documentation

Issue 16 – Log Injection (PR #1590)

- Status: **Submitted, under review**
- Mentor:
 - Prioritized for upcoming review

Issue 17 – Session Token Storage

- Status: **In progress (Krista)**
- Action:
 - Move toward **final/merge-ready state**

Issue 18 – HTTP Response Codes

- Status: **In progress (Andrew confirmed)**

Issue 19 – Business Logic Validation

- Status: **Low priority / unclear**
- Note:
 - Not a major focus for Sprint 6

Testing & Rate Limiting Discussion

A key technical discussion focused on **rate limiting interfering with tests**.

Problem:

- Expanded rate limits during testing prevent rate-limit tests from triggering

Proposed Solution:

- Separate test environments:
 - test (normal tests)
 - test_no_rate (rate limit tests)

Approach:

- Modify package.json test scripts
- Keep npm run test unchanged
- Run additional test sets internally

Action Items:

- Implement dual test strategy
- Ensure compatibility with GitHub Actions

Mentor Expectations for Sprint 6

The mentor emphasized:

1.

Do NOT leave unfinished work

- Everything must be:
 - Clean
 - Documented
 - Reviewable

2.

Stop coding early if needed

- If blocked → **document instead of rushing**

3.

Avoid exposing vulnerabilities

- Do NOT:

- Describe exact exploit methods in PRs
- Publicly expose security weaknesses

Repository & Access Concern

The mentor requested confirmation that:

- Team repositories (Ball State GitHub)
- Will remain accessible **long-term**
- Permissions will **not be revoked after the course**

Action Item:

- Confirm with professor

Additional Discussion – External Tools (Grafana / CI)

- External tools like **Grafana** may be considered
- Must:
 - Integrate properly with OED
 - Match architecture (React, Redux)
 - Be justified with a **design document**

CI:

- No plan to replace GitHub CI
- External CI tools unlikely to be adopted

Sprint 6 Reflection

Sprint 6 represents the **final consolidation phase** of the project.

Main takeaways:

- The project is **close to completion but not clean**
- Several issues are **technically done but not merge-ready**
- The biggest risks are:
 - Unresolved merge conflicts

- Lack of testing validation
- Missing documentation

The team must now transition from:

“Building and implementing”
to

“**Finalizing, validating, and delivering.**”

Next Steps

- Fix and finalize **Issue 1 (highest priority)**
- Clean and merge **PR #1554 and #1591**
- Resolve **Issue 6 (CSP warnings + conflicts)**
- Confirm status of **Issues 9 and 17**
- Complete **password validation (Issue 10)**
- Implement **test separation for rate limiting**
- Document:
 - Secret management approach
 - Remaining incomplete work
- Verify **repository access with professor**

Closing Note

The mentor emphasized that the goal is to leave the project in a **clean, usable, and professional state**, even if not every feature is fully completed.